

Railroad North

Applied OT & ICS Security Training

Presented to Engineering & Cyber Security Students

What is Operational Technology (OT)?

Unlike traditional IT networks that manage **data**, OT networks manage **physical processes**.

Traditional IT (Information Tech)

- **Priority:** Confidentiality & Data Protection
- **Impact:** Data breaches, financial loss
- **Lifespan:** Hardware replaced every 3-5 years
- **Patching:** Regular, automated updates

OT (Operational Tech)

- **Priority:** **Safety, Availability, Reliability**
- **Impact:** Physical damage, loss of human life
- **Lifespan:** Equipment runs for 15-30 years
- **Patching:** Extremely rare; requires system downtime

Introduction to the Railroad North Lab

This laboratory simulates a **Critical Infrastructure Railway System**. It is designed to safely teach you how these systems work and how they can be compromised.

The Core Mission You will step into the shoes of both an attacker and a defender. You will learn how to read industrial protocols, bypass physical safety interlocks, and finally, how to detect and stop these attacks using modern SOC (Security Operations Center) tools.

The Purdue Enterprise Reference Architecture

Our lab is segmented strictly according to the industry-standard Purdue Model.

Zone	Level	Components in our Lab
IT / Enterprise	Level 4	Engineering Workstations, Corporate File Transfers (Subnet: 172.26.x.x)
DMZ (Demilitarized)	Level 3.5	SCADA Web Dashboard, Syslog Aggregator, Secure Proxies (Subnet: 172.27.x.x)
OT / Control	Level 1-3	Master PLC, Zeek IDS, ELK Stack (Subnet: 172.25.x.x)
Field Devices	Level 0	Slave PLCs controlling Switches, Barriers, and Signals

Deep Dive: How the Railway is Controlled

To secure the railway, you must first understand how it operates.

1. The Master PLC (The Brain)

The Master Programmable Logic Controller acts as the central coordinator. It stores the "global truth" of the railway. It continuously polls the Slave PLCs every 5 seconds (Heartbeat) and enforces safety rules.

2. The Slave PLCs (The Muscle)

Located in the North, Central, and South segments. These directly open/close physical track switches and lower barriers. They blindly follow the Master's orders.

Modbus TCP: The Language of Industry

Our PLCs communicate using **Modbus TCP**, a protocol from 1979 that is still used globally today.

The Security Flaw: Modbus TCP has zero encryption and zero authentication. If you can reach the network port (502), the PLC will execute your command.

Key Modbus Functions You Will See:

- `Function 0x03 (Read Holding Registers)`: Used by the Master to check sensor states.
- `Function 0x06 (Write Single Register)`: Used by the SCADA UI to change a track route.
- `Function 0x0F (Write Multiple Coils)`: Used to trigger emergency stops.

Built-In Safety Interlocks (Defensive Logic)

To prevent catastrophic train derailments, our Master PLC has hard-coded safety logic:

1. **Track Occupancy Lock:** A track switch **will not operate** if the occupancy sensor detects a train currently on that specific segment.
2. **Barrier Enforcement:** Train routes cannot be cleared unless physical crossing barriers are confirmed to be lowered and locked.
3. **Heartbeat Monitoring:** If the Master PLC loses connection to a Slave PLC, it triggers a global **FAULT** state, halting all trains.

The Defender's Toolkit (SOC Stack)

Because Modbus is insecure by design, we must rely on **network monitoring** to secure the OT environment.

- **Zeek IDS:** An Intrusion Detection System. It performs Deep Packet Inspection (DPI) on port 502 to alert us to malformed Modbus traffic or unauthorized writes.
- **Syslog Collector:** Aggregates every command and error from the PLCs into a central server.
- **Elasticsearch & Logstash:** Ingests millions of log events and indexes them for rapid searching.
- **Kibana:** Our visual dashboard. Used by analysts to spot anomalies (like a sudden spike in Modbus traffic).

Training Scenarios

You will now execute and defend against four distinct cyber-physical attacks.

Scenario 1: Unauthorized Track Switching

The Concept: An adversary gains access to the OT network and attempts to switch a track route, bypassing the SCADA operator dashboard.

The Attack

The student will use a script to send a direct Modbus `Write Register (0x06)` command to the Master PLC from an unauthorized IP address.

The Defense

Identify the rogue IP address using the Kibana dashboard. Review the Zeek `notice.log` to see exactly which register was modified, and propose firewall segmentation rules.

Scenario 2: PLC Heartbeat Failure (DoS)

The Concept: A segment of the railway loses connectivity due to a cyber-attack (DoS) or a physical network cut.

The Attack

We will intentionally isolate a Slave PLC, severing its connection to the Master controller.

The Defense

Watch the Master PLC automatically trigger the safety interlock and enter a **FAULT** state. Students will use the logs to determine the exact timestamp of the network loss and execute the standard E-STOP recovery procedure.

Scenario 3: Safety Interlock Bypass

The Concept: What happens if an attacker manipulates the sensor data that the safety logic relies on?

The Attack

The attacker forces the "Occupancy Sensor" value on a Slave PLC to `False` (Clear), tricking the Master PLC into allowing a track switch while a train is actually present.

The Defense

This is the most dangerous scenario. Students will analyze the logs for impossible physics (e.g., a track clearing in 0.1 seconds) and learn to write custom Zeek rules to alert on rapid sensor-state toggling.

Scenario 4: Modbus Protocol Fuzzing

The Concept: Attackers often map out a network before striking. We must detect them during the reconnaissance phase.

The Attack

Students will use the `modbus-attack.py` toolkit to rapidly scan the PLC and send malformed function codes to map out the memory registers.

The Defense

Identify the automated scanning patterns in the network traffic. Detect the specific `Illegal Function` exception codes being dropped and logged by the PLCs.

Lab Execution & Deliverables

Your task is to work through these scenarios on your local lab instance.

1. **Access the Dashboard:** Go to <http://localhost:8080> to view the SCADA system.
2. **Review the Logs:** Analyze the output of the Master PLC and the Syslog collector.
3. **Document Findings:** For each scenario, document the Attack Vector, the resulting System Impact, and the Defensive Mitigation.

Questions & Lab Kickoff

Please navigate to your local lab instance to begin.

The TA will be walking around to assist with networking or Docker issues.